

ADVERSARY SIMULATION & PENETRATION TESTING LAB

Vulnerability Assessment and Penetration Testing Report

Prepared by: Gaurav Kalra

Environment: Isolated Virtualized Security Lab

Assessment Type: Authorized Internal VAPT

Status: Project Report Template — populate with actual evidence

Confidentiality Notice: This document is intended for educational, portfolio, and authorized lab-use purposes only.

1. Executive Summary

This report documents the design and intended assessment workflow of an isolated adversary simulation and penetration-testing laboratory. The environment uses pfSense as a perimeter firewall/router, Kali Linux as the attacker platform, Linux and DVWA as target systems, and Nmap, Metasploit, Burp Suite, and Wireshark for security testing and traffic analysis.

The lab is designed to reproduce selected enterprise security concepts, including network segmentation, NAT, firewall enforcement, reconnaissance, service enumeration, web application vulnerability validation, evidence collection, and remediation planning.

Assessment conclusion: The final risk posture must be determined from the actual scan output, screenshots, packet captures, and verified findings collected during testing. This report therefore separates planned test cases from confirmed results.

Assessment Summary

Item	Description
Assessment scope	Isolated virtual machines and intentionally vulnerable DVWA application
Primary firewall	pfSense
Attacker platform	Kali Linux
Target platform	Linux / DVWA
Testing focus	Network security, web application security, traffic analysis
Methodology	Reconnaissance → Enumeration → Validation → Evidence → Risk → Remediation
Overall status	Evidence to be completed by assessor

2. Scope and Rules of Engagement

Testing is limited to the virtual machines, networks, applications, and services explicitly owned or authorized by the lab operator.

In Scope	Out of Scope
pfSense configuration and firewall rules	Public internet systems
Attacker and target VLANs	Third-party infrastructure
DVWA application and its supporting services	Real user accounts or personal data
Authorized packet captures and logs	Destructive actions outside the lab

Testing should be performed without exposing vulnerable systems to an uncontrolled network. Any credentials, private keys, tokens, or sensitive host information should be removed before publishing this report.

3. Lab Architecture

The lab is designed around separated attacker and target network segments. pfSense provides routing, NAT, firewall enforcement, and segmentation between the networks.

Logical topology

Internet / Virtual NAT
↓
pfSense Firewall and Router
■■■ Attacker VLAN / Network – Kali Linux
■■■ Target VLAN / Network – Linux + DVWA

Component	Role	Evidence to attach
pfSense	Firewall, router, NAT, VLAN segmentation	Dashboard, interfaces, rules, NAT screenshots
Kali Linux	Reconnaissance and authorized exploitation	Terminal and tool screenshots
Linux target	Hosts vulnerable application/services	IP configuration and service screenshots
DVWA	Intentionally vulnerable web application	Application and test-result screenshots
Wireshark	Packet capture and traffic analysis	Capture screenshots and analysis notes

4. Tools and Technologies

Tool	Purpose
pfSense	Firewall, routing, NAT, VLANs, traffic filtering
Kali Linux	Security assessment and penetration-testing platform
DVWA	Controlled vulnerable web application target
Nmap	Host discovery, port scanning, service enumeration
Metasploit	Controlled exploit validation where applicable
Burp Suite	HTTP request interception and web testing
Wireshark	Packet capture and network traffic analysis
Linux	Target operating system and service hosting
MITRE ATT&CK	Mapping relevant adversary techniques

5. Methodology

5.1 Reconnaissance

Identify authorized hosts, reachable networks, open ports, and exposed services.

5.2 Service Enumeration

Determine service versions, web endpoints, application functionality, and potential attack surface.

5.3 Vulnerability Identification

Review DVWA modules and exposed services for known or intentionally introduced weaknesses.

5.4 Exploitation Validation

Use controlled techniques to confirm whether a suspected vulnerability is exploitable and to record its impact.

5.5 Post-Exploitation Analysis

Within the lab, confirm the level of access obtained, affected assets, permissions, and possible security consequences.

5.6 Evidence and Reporting

Record commands, timestamps, screenshots, request/response data, packet captures, severity, and remediation.

6. Test Cases and Findings

The following findings are assessment categories to be validated. Replace each status with Confirmed, Not Reproducible, Not Applicable, or Not Tested, and attach evidence for confirmed findings.

ID	Finding	Validation Source	Status	Recommended Remediation
F-01	Network service exposure	Nmap	To be determined	Restrict unnecessary services; review firewall exposure.
F-02	SQL Injection	DVWA / Burp Suite / SQLmap	To be determined	Parameterized queries, input validation, least-privilege DB account.
F-03	Cross-Site Scripting	DVWA / Burp Suite	To be determined	Context-aware output encoding, validation, CSP.
F-04	CSRF	DVWA / HTTP request analysis	To be determined	Anti-CSRF tokens, SameSite cookies, origin checks.
F-05	Command Injection	DVWA	To be determined	Avoid shell calls; allowlists; least privilege.
F-06	File Inclusion	DVWA	To be determined	Allowlisted file mappings; safe path handling.
F-07	Firewall segmentation weaknesses	pfSense / Wireshark	To be determined	Deny-by-default rules; restrict inter-VLAN traffic.

7. Network Traffic Analysis

Wireshark should be used to inspect authorized traffic generated during the assessment. Analysis may include TCP connections, HTTP requests and responses, DNS activity, routing behavior, and evidence that pfSense rules permit or block intended flows.

Suggested display filters:

```
http
tcp
dns
ip.addr == <TARGET_IP>
```

Attach packet-capture screenshots and explain what each capture proves. Avoid publishing credentials, session cookies, or other sensitive values.

8. Risk Rating Method

Risk should be assigned using a consistent methodology such as CVSS or an organization-defined severity model. Consider exploitability, required access, user interaction, confidentiality, integrity, availability, affected assets, and the actual impact observed in the lab.

Severity	General interpretation
Critical	Severe impact with broad compromise potential; requires urgent treatment.
High	Significant compromise or sensitive impact under realistic conditions.
Medium	Meaningful security weakness with limited or conditional impact.
Low	Limited impact or defense-in-depth issue.
Informational	Observation or hardening recommendation without demonstrated material impact.

9. MITRE ATT&CK; Mapping

Technique	ID	Possible lab relevance
Network Service Scanning	T1046	Nmap reconnaissance of authorized target network
Exploit Public-Facing Application	T1190	Only if an exposed application is actually exploited
Command and Scripting Interpreter	T1059	Only if command execution is demonstrated
Valid Accounts	T1078	Only if authorized account-based testing is performed

Mapping must reflect the exact observed activity. Do not map techniques merely because a tool is installed or because a vulnerability category exists.

10. Remediation Recommendations

- Maintain strict isolation of intentionally vulnerable systems.
- Use deny-by-default firewall rules and permit only required lab traffic.
- Separate attacker, target, management, and monitoring networks where practical.
- Remove unnecessary services and restrict administrative interfaces.
- Use parameterized queries and context-aware output encoding in applications.
- Apply anti-CSRF protections and secure cookie attributes.
- Avoid passing untrusted input to operating system commands.
- Use allowlists and safe path handling for file access.
- Monitor and review logs, packet captures, and firewall events.
- Retest after remediation and record the new evidence.

11. Evidence Register

Evidence ID	Description	Location / Filename	Status
E-01	Network topology	Architecture/network-topology.png	To attach
E-02	pfSense interfaces and VLANs	pfSense/screenshots/	To attach
E-03	Firewall and NAT rules	pfSense/screenshots/	To attach
E-04	Nmap output	Reconnaissance/nmap-results.txt	To attach
E-05	DVWA test evidence	Exploitation/	To attach
E-06	Wireshark capture analysis	Network-Analysis/	To attach
E-07	Final VAPT report	Reports/	This document

12. Conclusion

This lab provides a controlled environment for practicing network security architecture, reconnaissance, vulnerability validation, web application testing, packet analysis, and professional reporting. The final security conclusions should be based on reproducible evidence collected from the authorized environment.

For publication on GitHub, include the README, architecture diagram, selected screenshots, sanitized notes, findings, remediation recommendations, and this report. Do not publish secrets, private keys, real credentials, or uncontrolled vulnerable VM exports.

Appendix A — Assessor Notes

Assessment date: _____

Assessor: _____

Virtualization platform: _____

Target IP(s): _____

pfSense version: _____

Kali Linux version: _____

DVWA version / security level: _____

Report reviewer: _____